JU TECHFEST 2026 · CY-02 ARCHITECTURE & ENGINEERING REVIEW

PatchPilot AI

Autonomous Security Review, Auto-Remediation & Fix Verification Platform

Author: Akash Kushwaha
Project: PatchPilot AI Full-Stack
Repository: Akashkushwaha04/PatchPilot
Test Status: 119/119 Unit & Integration Tests Passed (100%)

28	119	4-in-1
MITRE CWE SECURITY RULES	AUTOMATED TEST CASES	SAST · SCA · DAST · IAC

1. Executive Summary & Core Value Proposition

With the explosion of *vibe coding* and rapid prototyping powered by modern AI assistants, developers are shipping functional applications at unprecedented speed. However, these applications frequently ship with severe latent vulnerabilities: leaked API credentials, missing authentication gates, unparameterized SQL statements, vulnerable dependencies, and insecure deployment configurations.

PatchPilot AI is a full-stack security reviewer that transforms raw codebases into production-hardened applications through three unique pillars:

1. **Multi-Engine Detection:** Deep static AST analysis, open-source Semgrep taint analysis, dependency vulnerability correlation via Google OSV, headless browser network sniffing via Playwright, and Infrastructure as Code (Docker) security auditing.
2. **Autonomous AI & Rule Auto-Fixing:** Generates secure, path-safe unified diffs and automatically branches, commits, and opens detailed Pull Requests on GitHub detailing resolved CWEs.
3. **Mathematical Verification & Regression Prevention:** Rather than assuming a fix works, PatchPilot rescans the corrected code, computing delta scores and proving that resolved issues are eliminated without introducing new security regressions.

2. Comprehensive Feature Breakdown & Architecture Strengths

Static Analysis (SAST) & Semgrep Engine

Custom AST-based pattern matching and Semgrep CLI subprocess wrapper mapping deep taint-tracking results into a unified finding schema with file, line, severity, and evidence context.

Dynamic Secret Verification

Distinguishes dummy/revoked tokens from active credentials by performing safe, non-destructive read-only API calls (AWS STS `GetCallerIdentity`, GitHub `/user`), dynamically escalating live keys to **Critical**.

Software Composition Analysis (SCA)

Parses `package.json` and `requirements.txt` dependencies and executes concurrent asynchronous queries against the Google OSV API to surface known CVEs and fixed versions.

Headless DAST with Playwright

Navigates live web applications using headless Chromium, waits for client-side SPA rendering, intercepts network calls for exposed internal APIs/tokens, and blocks private IP ranges against SSRF.

Infrastructure as Code (IaC) Rules

Evaluates `Dockerfile` and `docker-compose.yml` for container execution as root (CWE-250), dangerous daemon port bindings (e.g., 2375), and absent CPU/memory bounds (CWE-770).

Framework-Aware Authorization Engine

Intelligently verifies Next.js `middleware.ts` JWT authentication and Supabase migration Row Level Security (RLS) policies, dismissing false positives on protected routes.

GitHub URL Ingestion & Automated Pull Request Pipeline

To avoid the security hazards of `git clone` (such as malicious git hooks execution), PatchPilot consumes repositories via the GitHub REST API zipball archive endpoint. Downloaded code streams directly into chunked memory with zip-bomb limits. Upon user approval, PatchPilot's auto-fix engine applies verified code replacements and uses **PyGithub** to create a dedicated branch (`patchpilot-security-fixes-{timestamp}`), commit modifications, and open a Pull Request with an interactive Markdown breakdown of resolved CWEs.

> **Security Invariant: Zero-Persistence Credential Storage**
> Personal Access Tokens (PATs) and API secrets are never saved to the SQLite database or disk. They are held strictly in ephemeral RAM for the active session duration only.

3. Detection Rules & Vulnerability Coverage

PatchPilot inspects and enforces 28 security rules mapped to standard MITRE Common Weakness Enumerations:

Rule ID	Vulnerability Description	Severity	CWE Mapping	Automated Remediation Approach
PP-SEC-001	Hardcoded Provider Secret Key (OpenAI, Anthropic, Stripe, AWS)	Critical	CWE-798	Replace with environment variable lookup (`process.env` / `os.environ`)
PP-SEC-004	Secret exposed via Frontend Prefix (`VITE_`, `NEXT_PUBLIC_`)	Critical	CWE-200	Strip frontend prefix and relocate credential to backend service
PP-SEC-005	Database Connection String with Embedded Password	High	CWE-798	Replace with parameterized `DATABASE_URL` environment variable
PP-INJ-001	SQL Injection via String Concatenation / f-string	High	CWE-89	Convert raw query to parameterized prepared statement
PP-INJ-002	Dynamic Shell Command Execution (`exec`, `system`)	Critical	CWE-78	Replace with `execFile` / `subprocess.run(shell=False)` with array arguments
PP-AUTH-002	Server Trusts Client-Supplied Role (e.g. `?isAdmin=true`)	Critical	CWE-639	Enforce verified server-side session and signed JWT role lookup
PP-XSS-001	Unsanitized `dangerouslySetInnerHTML` Injection	High	CWE-79	Sanitize payload using `DOMPurify.sanitize()`
PP-CFG-001	Permissive Wildcard CORS Configuration (*)	Medium	CWE-942	Restrict origin to explicit trusted domains
PP-CFG-003	Disabled TLS Certificate Verification (`verify=False`)	High	CWE-295	Enforce strict TLS certificate chain validation
PP-IAC-001	Container Runs as Root (`USER root` in Dockerfile)	High	CWE-250	Add dedicated unprivileged user (`USER appuser`)
PP-IAC-003	Missing CPU / Memory Resource Limits in Docker Compose	Low	CWE-770	Add explicit deploy resource limits (e.g. 512M RAM, 0.5 CPU)
PP-SCA-001	Vulnerable Third-Party Dependency (Google OSV CVE)	High	CWE-1395	Upgrade package dependency to minimum patched semantic version

4. Interactive Frontend User Experience

- **Clickable Severity Distribution Cards:** The scan results view presents interactive count buttons for Critical, High, Medium, Low, and Info. Clicking a card isolates findings of that tier, triggers a color-matched double-ring visual state, and auto-syncs the code inspection pane.
- **Dashboard Findings Drill-Down:** Global `SeverityFindingsDialog` enables clicking any severity bar on the dashboard overview to preview matching issues across all projects with code snippets and one-click scan navigation.
- **Interactive Code Inspector:** Displays syntax-highlighted source code with masked secrets (preventing credentials from ever appearing on client screens) and rule evidence callouts.
- **Side-by-Side Fix Verification:** Visual delta breakdown displaying resolved, remaining, and newly introduced issues alongside before-and-after numerical security scores (0–100).

5. Strategic Engineering Roadmap: Where to Work Next

To evolve PatchPilot from a cutting-edge hackathon winner into an enterprise-grade developer security platform, focus development on the following prioritized milestones:

Priority 1: Reusable CI/CD GitHub Action & GitLab CI Component
Package PatchPilot as a GitHub Action (`uses: Akashkushwaha04/patchpilot-action@v1`). Automatically scan pull requests on push, post inline PR comments on vulnerable lines, and block merging if new Critical or High findings are introduced.

Priority 2: Dockerized Self-Healing Verification Sandbox
Before committing an AI-generated auto-fix to a user's repository, run the project's automated test suite (`pytest`, `npm test`) inside an ephemeral, isolated container. If tests break, feed the error back to the LLM to self-heal until tests pass.

Priority 3: Multi-Language & Monorepo Expansion
Extend AST and semantic parsers to support **Go** (using tree-sitter-go), **Java / Kotlin** (Maven & Gradle), and **Rust** (Cargo). Add monorepo root detection for Turborepo, Nx, and pnpm workspaces.

Priority 4: Deep Historical Git Secret Scanning
Integrate TruffleHog / Gitleaks to traverse entire commit histories. Developers frequently commit API keys and delete them in a subsequent commit, leaving the credential exposed forever in git history.

Priority 5: Multi-Tenant Team Workspaces & Alert Hub
Add organization accounts, team workspaces, Role-Based Access Control (RBAC), SSO via GitHub/Google, and real-time webhook integrations for Slack, Discord, Microsoft Teams, and PagerDuty.
